COMPTIA SECURITY+ SY0-701 DOMÍNIO 3 · ARQUITETURA DE SEGURANÇA (18%)

Security+ 3.2 · Network Appliances

Mestre CyberSec · **Aula 3.2 — Network Appliances** (11:56) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Appliances: jump server (única entrada pra admin); proxy (intermedia HTTP — cache/filter/auth); load balancer (distribui); sensors (IDS/IPS); collectors (junta logs pra SIEM).

💡 Highlights que a prova CompTIA cobra

- Jump box: única porta de ADMINISTRACAO — reduz surface
- Proxy: cache + filter + auth no tráfego HTTP
- Load balancer: distribui e dá redundância

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'single entry point for administrators' = jump server

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 3.2 — Network Appliances)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Servidor de salto (Jump box) (N/A)

Servidor endurecido e isolado que atua como ponto único de entrada administrativa para gerenciar sistemas críticos; administradores conectam-se a ele primeiro e depois acessam outros dispositivos.

⚠ ***Armadilha CompTIA:*** *Palavra-chave: 'single entry point for administrators' = jump server. Não confunda com proxy ou VPN; o foco é acesso administrativo controlado e auditado.*

• Servidor Proxy (N/A)

Aplicação intermediária que trata requisições de clientes, geralmente HTTP/HTTPS, oferecendo cache, filtragem de conteúdo, autenticação e logs.

⚠ ***Armadilha CompTIA:*** *Se a questão mencionar cache, filtro de URL/conteúdo e autenticação no tráfego web, pense em proxy. Forward proxy = atende clientes internos; reverse proxy = protege servidores internos.*

• Proxy Direto (Forward Proxy) (N/A)

Proxy posicionado entre usuários internos e redes externas, encaminhando requisições de saída dos clientes para a Internet e aplicando políticas.

⚠ ***Armadilha CompTIA:*** *Exam trigger: internal users accessing external sites through a proxy. It hides client IPs and filters outbound traffic. Not the same as reverse proxy.*

• Proxy Reverso (N/A)

Proxy colocado à frente de servidores internos para aceitar requisições de clientes externos, oferecendo balanceamento de carga, cache, terminação TLS e proteção.

⚠ ***Armadilha CompTIA:*** *Exam trigger: external clients accessing internal web servers; reverse proxy hides servers and can offload TLS/SSL. Contrast with forward proxy.*

• Balanceador de Carga (LB)

Dispositivo de rede que distribui o tráfego de entrada entre vários servidores para melhorar desempenho, disponibilidade e redundância.

⚠ ***Armadilha CompTIA:*** *Se a questão citar distribuição de tráfego, failover, health checks ou alta disponibilidade, escolha load balancer. Pode ser L4 (TCP/UDP) ou L7 (HTTP).*

• Sensores (IDS/IPS)

Sensores de rede monitoram tráfego em busca de atividade maliciosa; IDS detecta e alerta, enquanto IPS pode bloquear ou prevenir intrusões ativamente.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'detecta e alerta' = IDS; 'detecta e bloqueia' = IPS. Sensor é o componente que coleta/monitora o tráfego para o IDS/IPS.*

• Coletor (N/A)

Coletor de logs agrega e encaminha dados de log de várias fontes para um sistema central, geralmente um SIEM, para correlação e análise.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'aggregates logs' or 'feeds SIEM' = collector. It does not analyze by itself; it centralizes/forwards logs.*

• Gerenciamento de Informações e Eventos de Segurança (SIEM)

Plataforma centralizada que coleta, correlaciona e analisa logs e eventos de segurança de múltiplas fontes para apoiar detecção e resposta.

⚠️ ***Armadilha CompTIA:*** *Se a questão falar em correlação de logs, dashboards, alertas centralizados e retenção para investigação, pense em SIEM. Collectors alimentam o SIEM.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Módulo de Segurança em Hardware (HSM - Hardware Security Module)

🏠 **Analogia Intuitiva:** É um cofre de titânio suíço com blindagem anti-arrombamento instalada no rack do data center: as chaves criptográficas mestras são geradas e trancadas lá dentro e NUNCA saem para a memória do servidor nem para o disco. Se alguém tentar abrir a tampa do cofre com uma chave de fenda, um circuito interno detecta a vibração, queima os chips de memória e destrói as chaves imediatamente (Zeroization).

🔍 **Causa Raiz / Por que foi criado:** Servidores operacionais comuns armazenam chaves criptográficas na memória RAM ou em arquivos no disco, onde podem ser roubadas por malwares, despejos de memória (memory dumps) ou invasores com acesso root. O HSM isola o ciclo de vida criptográfico em hardware certificado (FIPS 140-2/3 Nível 3 ou 4).

🛡️ **Visão do Auditor de GRC:** Verificar se as chaves de Autoridade Certificadora Raiz (Root CA), chaves de assinatura de pagamentos (PCI-DSS) e criptografia mestre de banco de dados estão custodiadas em HSMs com certificação FIPS; auditar procedimento de cerimônia de chaves (Key Ceremony).

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'dedicated physical hardware appliance certified to securely generate, store, and manage cryptographic keys with tamper-evident zeroization'. Resposta: HSM (Hardware Security Module).

📌 SIEM vs. SOAR: O Cérebro Analítico vs. O Robô de Resposta Automática

🏠 **Analogia Intuitiva:** O SIEM é o grande telão da torre de controle: ele coleta registros de 1.000 câmeras e sensores, cruza os horários e acende uma luz amarela dizendo: 'Atenção, o funcionário João logou no RH em São Paulo e 2 minutos depois logou em Londres' (agregação e correlação de logs). O SOAR é o robô de resgate automatizado: no mesmo segundo em que a luz amarela acende, o robô roda um script predefinido (Playbook), bloqueia o usuário João no Active Directory, encerra as sessões ativas e avisa o plantonista no Telegram.

🔍 **Causa Raiz / Por que foi criado:** O SIEM resolve a necessidade de centralizar terabytes de logs desconexos e correlacionar eventos de segurança. O SOAR resolve o gargalo humano: analistas não conseguem responder manualmente a milhares de alertas por segundo, então o SOAR orquestra ferramentas e automatiza a resposta.

🛡️ **Visão do Auditor de GRC:** Inspecionar fontes de logs enviadas ao SIEM e conferir sincronização NTP em todos os nós; auditar playbooks do SOAR para garantir que ações automatizadas de bloqueio não interrompam serviços de missão crítica.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'centralizes log collection and correlates events across heterogeneous devices'. Resposta: SIEM. 'Automates security response workflows and executes incident playbooks across multiple security tools' -> SOAR.

📌 WAF vs. NGFW: O Especialista em Navegador Web vs. O Guarda de Fronteira Geral

🏠 **Analogia Intuitiva:** O NGFW (Firewall de Nova Geração) é a alfândega do aeroporto internacional: ele confere passaportes, inspeciona se há armas e drogas em qualquer mala, sabe diferenciar um piloto de um turista e barra conexões maliciosas em qualquer porta ou protocolo. O WAF (Web Application Firewall) é o crítico de arte gastronômica que inspeciona exclusivamente os pratos do restaurante italiano da praça de alimentação: ele lê o molho de cada prato para garantir que ninguém colocou veneno ou pedras no macarrão (protege especificamente aplicações web contra SQL Injection e Cross-Site Scripting).

🔍 **Causa Raiz / Por que foi criado:** O NGFW protege o tráfego corporativo amplo (L3 a L7), mas não analisa profundamente os parâmetros complexos de formulários HTTP. O WAF é especializado nas ameaças do OWASP Top 10 que atacam diretamente a lógica e os bancos de dados de aplicações web.

🛡️ **Visão do Auditor de GRC:** Verificar se aplicações web expostas à Internet e que processam cartões de crédito possuem WAF obrigatório conforme exigido pelo PCI-DSS Requisito 6.6; certificar a ativação de inspeção SSL/TLS nos NGFWs.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'appliance placed in front of public web servers specifically designed to protect against SQL injection and Cross-Site Scripting (XSS)'. Resposta: Web Application Firewall (WAF).

📌 DLP de Rede (Data Loss Prevention): O Fiscal da Porta de Saída de Dados

🏠 **Analogia Intuitiva:** É o fiscal de saída da alfândega com aparelho de raio-X inspecionando cada caminhão e pacote que tenta cruzar a fronteira para o exterior: se ele enxergar formatos que se parecem com 16 dígitos de cartões de crédito, CPFs ou arquivos com marca d'água 'CONFIDENCIAL', ele bloqueia a carga na hora e aciona o alarme antes que o caminhão saia do país.

🔍 **Causa Raiz / Por que foi criado:** Exfiltração de dados confidenciais por funcionários mal-intencionados ou malwares enviando arquivos confidenciais por e-mail, uploads web ou conexões FTP não autorizadas.

🛡️ **Visão do Auditor de GRC:** Conferir a eficácia das regras de correspondência padrão (expressões regulares para números de cartões com algoritmo de Luhn e CPF); verificar se o Network DLP inspeciona tráfego criptografado através de quebra de SSL corporativa.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'prevents unauthorized exfiltration of sensitive proprietary data, credit card numbers, and PII across network egress points'. Resposta: Network DLP (Data Loss Prevention).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Equipamento físico dedicado que gera e armazena chaves criptográficas com proteção contra violação física e autodestruição	**HSM (Hardware Security Module)**
Sistema centralizado de coleta, retenção, normalização e correlação em tempo real de logs de eventos de segurança	**SIEM (Security Information and Event Management)**
Plataforma que automatiza a triagem de incidentes e executa playbooks programados para bloquear ameaças sem ação humana	**SOAR (Security Orchestration, Automation, and Response)**
Dispositivo especializado em filtrar e bloquear ataques direcionados especificamente a aplicações web, como SQL Injection e XSS	**WAF (Web Application Firewall)**
Firewall avançado capaz de identificar aplicações independentemente da porta utilizada e realizar inspeção profunda de pacotes (DPI)	**NGFW (Next-Generation Firewall)**
Dispositivo de segurança que monitora o tráfego de saída da rede para impedir vazamento acidental ou roubo de dados confidenciais	**Network DLP (Data Loss Prevention)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um administrador de sistemas precisa fornecer acesso administrativo remoto seguro a uma rede de gerenciamento reforçada que hospeda dispositivos de rede, hypervisors e controladoras de armazenamento. A equipe de segurança exige que nenhuma conexão administrativa de entrada direta seja permitida a esses ativos críticos de fora da rede. Qual appliance de rede deve ser implantado como ponto de entrada único e controlado para sessões administrativas nessa zona de gerenciamento isolada?

A) Um jump server colocado em uma sub-rede protegida que intermedia todas as sessões administrativas para a rede de gerenciamento

B) Um reverse proxy configurado para terminar TLS para tráfego HTTPS administrativo de entrada para endpoints de gerenciamento

C) Um sensor IPS inline executando inspeção profunda de pacotes no tráfego da VLAN de gerenciamento

D) Um load balancer com distribuição round-robin entre as controladoras de gerenciamento

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa de médio porte deseja reduzir custos de banda e aplicar políticas de uso aceitável para o tráfego web de saída de 800 funcionários. A equipe de segurança também precisa bloquear domínios maliciosos conhecidos e impedir que os usuários enviem documentos sensíveis para serviços de armazenamento em nuvem não autorizados. Qual appliance melhor atende aos três requisitos ficando entre os usuários e a Internet?

A) Um forward proxy que inspeciona requisições HTTP/HTTPS de saída, aplica filtragem de conteúdo e armazena em cache objetos acessados frequentemente

B) Um reverse proxy implantado à frente dos servidores de arquivos internos para cache de downloads

C) Um jump server usado como gateway padrão para todas as estações de trabalho dos funcionários

D) Um sensor IDS de rede colocado na borda da Internet em modo de monitoramento passivo

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa de e-commerce está hospedando uma aplicação de checkout pública em múltiplos servidores web internos atrás de um único endereço IP público. O engenheiro de segurança quer terminar TLS em um appliance de perímetro, ocultar a topologia interna dos servidores dos atacantes e inspecionar requisições de entrada em busca de payloads maliciosos antes que cheguem aos servidores de aplicação. Qual appliance deve ser implantado na DMZ?

A) Um reverse proxy que termina HTTPS de entrada, realiza inspeção das requisições e encaminha o tráfego limpo para o servidor web backend apropriado

B) Um forward proxy configurado como gateway padrão em cada servidor web

C) Um jump server que intermedia todas as sessões HTTPS dos clientes para o banco de dados

D) Um sensor IDS passivo que espelha o tráfego da porta SPAN do switch da DMZ

QUESTÃO 4 · CENÁRIO DE EXAME

Um serviço de streaming está apresentando tempos de resposta lentos durante o horário nobre. A equipe de aplicação implantou seis servidores de aplicação idênticos no data center, mas uma verificação de saúde revela que um servidor está retornando erros HTTP 503. O arquiteto de rede quer remover automaticamente o servidor com falha do pool, distribuir novas conexões de clientes均匀emente entre os servidores saudáveis e fornecer SSL offloading. Qual appliance atende a esses requisitos?

A) Um load balancer que realiza health checks, distribui o tráfego via round-robin ou least-connections e faz offloading da descriptografia TLS para otimizar o desempenho dos backends

B) Um reverse proxy com um registro DNS A estático apontando para o primeiro servidor disponível

C) Um jump server configurado com túneis SSH para cada nó de aplicação

D) Um sensor IPS inline que bloqueia respostas HTTP malformadas do backend

QUESTÃO 5 · CENÁRIO DE EXAME

Uma equipe de operações de segurança precisa de um dispositivo de rede que monitore o tráfego east-west entre máquinas virtuais dentro do data center, copie pacotes para análise e gere alertas quando assinaturas de padrões de ataque conhecidos forem correspondidas. O dispositivo NÃO deve modificar ou bloquear o tráfego porque a equipe quer apenas visibilidade para ajustar regras de detecção. Qual implantação melhor se adapta a esse requisito?

A) Um sensor IDS passivo conectado a uma porta SPAN/mirror que analisa cópias do tráfego e gera alertas em correspondências de assinatura

B) Um sensor IPS inline colocado em série com o fluxo de tráfego das VMs que descarta pacotes correspondentes

C) Um reverse proxy que termina todas as conexões HTTP entre VMs

D) Um load balancer que distribui tráfego entre os virtual switches do hypervisor

QUESTÃO 6 · CENÁRIO DE EXAME

Após vários ataques de SQL injection bem-sucedidos terem evadido a detecção baseada em assinatura, a equipe de segurança quer um dispositivo inline à frente dos servidores web públicos que possa inspecionar o corpo das requisições HTTP, descartar requisições maliciosas em tempo real e atualizar suas assinaturas automaticamente a partir do feed de ameaças do fornecedor. Qual appliance a equipe deve implantar?

A) Um sensor IPS inline colocado no caminho da rede que realiza inspeção profunda de pacotes e bloqueia ativamente o tráfego malicioso

B) Um IDS passivo conectado a uma porta SPAN que apenas registra payloads suspeitos

C) Um reverse proxy configurado para servir conteúdo estático a partir do cache

D) Um jump server que intermedia todas as conexões de banco de dados do tier de aplicação

QUESTÃO 7 · CENÁRIO DE EXAME

Uma organização multinacional tem firewalls, switches, servidores e agentes de endpoint gerando milhões de entradas de log por dia em diferentes formatos e fusos horários. O SOC quer um ponto único de coleta que normalize timestamps e formatos, enriqueça eventos e os encaminhe para uma plataforma analítica de longo prazo para correlação. Qual appliance melhor desempenha esse papel?

A) Um coletor de logs que recebe eventos de diversas fontes, normaliza em um esquema comum, enriquece os dados e os encaminha para o SIEM

B) Um sensor IPS inline que descarta tráfego suspeito e grava alertas em armazenamento local

C) Um jump server que intermedia todas as sessões administrativas e as grava em um arquivo de texto

D) Um reverse proxy que registra toda requisição HTTP em seu log de acesso

QUESTÃO 8 · CENÁRIO DE EXAME

Um analista do SOC quer consultar uma plataforma centralizada que combine logs de firewall, logs de eventos do Windows, alertas de IDS, logs de proxy web e eventos de autenticação em uma visão única. A plataforma deve suportar regras de correlação que combinem eventos de diferentes fontes para identificar ataques multi-estágio, como phishing levando a movimento lateral. Qual solução melhor atende a esse requisito?

A) Um SIEM que ingere eventos normalizados de múltiplos coletores, correlaciona entre fontes e fornece dashboards e alertas

B) Um jump server standalone que agrega logs de texto em um único diretório

C) Um sensor IPS inline que consolida assinaturas de múltiplos fornecedores

D) Um reverse proxy que combina logs de acesso dos servidores web frontend e backend

QUESTÃO 9 · CENÁRIO DE EXAME

Uma pequena empresa financeira tem 12 servidores, vários switches e dois firewalls espalhados entre um data center e uma filial. O CISO quer uma forma simples e segura para os administradores realizarem manutenção rotineira em todos os dispositivos sem expor SSH ou RDP diretamente à Internet. A solução também deve produzir um único log de auditoria de quem fez o quê e quando em todas as ações administrativas. Qual design melhor atende a esses objetivos?

A) Implantar um jump server reforçado na VLAN de gerenciamento, exigir que todos os admins se autentiquem nele primeiro e encaminhar seus logs de sessão para o SIEM

B) Abrir a porta TCP 22 no firewall de perímetro com uma política forte de senhas para acesso SSH direto

C) Substituir os firewalls por um único sensor IDS em modo de monitoramento passivo

D) Usar um reverse proxy público sem autenticação para expor as interfaces de gerenciamento

QUESTÃO 10 · CENÁRIO DE EXAME

Um arquiteto corporativo está projetando o perímetro de um novo data center e precisa decidir onde colocar vários appliances. Clientes internos navegarão na Internet, usuários públicos alcançarão um cluster de servidores web, o SOC precisa de visibilidade sobre padrões de tráfego malicioso e admins devem alcançar todos os dispositivos internos de forma segura. Qual posicionamento combina corretamente cada appliance com sua função?

A) Forward proxy para tráfego de saída dos clientes, reverse proxy na DMZ para tráfego web de entrada, sensor IDS/IPS no perímetro para detecção/prevenção e jump server para acesso administrativo

B) Reverse proxy para navegação de saída, forward proxy para tráfego web de entrada, jump server para inspeção de tráfego e sensor IDS para acesso administrativo

C) Jump server na DMZ servindo tráfego público, forward proxy para sessões administrativas, sensor IDS terminando TLS e reverse proxy como gateway padrão

D) Sensor IDS fazendo cache de conteúdo web de saída, forward proxy inspecionando HTTPS de entrada, jump server bloqueando SQL injection e reverse proxy fornecendo acesso administrativo

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Um jump server colocado em uma sub-rede protegida que intermedia todas as sessões administrativas para a rede de gerenciamento

Um jump server (jump box) é a resposta padrão da CompTIA para fornecer um ponto de entrada único, auditado e controlado em uma zona administrativa ou de gerenciamento reforçada. Ele intermedia conexões RDP/SSH, reduz a superfície de ataque eliminando o acesso administrativo direto de entrada e produz um trilha de auditoria centralizada. Um reverse proxy protege serviços web, não protocolos administrativos genéricos; um IPS inspeciona o tráfego, mas não intermedia sessões; um load balancer distribui tráfego de aplicação, não sessões administrativas.

Questão 2: Alternativa A — Um forward proxy que inspeciona requisições HTTP/HTTPS de saída, aplica filtragem de conteúdo e armazena em cache objetos acessados frequentemente

Um forward proxy é projetado para ficar em nome dos clientes internos fazendo requisições de saída para a Internet. Ele faz cache de conteúdo para reduzir banda, aplica controle de uso aceitável e políticas de DLP e pode bloquear destinos maliciosos. Um reverse proxy serve tráfego de entrada para servidores internos; um jump server é para acesso administrativo; um IDS em modo passivo observa o tráfego, mas não aplica filtragem de saída.

Questão 3: Alternativa A — Um reverse proxy que termina HTTPS de entrada, realiza inspeção das requisições e encaminha o tráfego limpo para o servidor web backend apropriado

Um reverse proxy fica à frente dos servidores internos para representá-los para os clientes externos. Ele termina TLS, oculta endereçamento/topologia internos, pode realizar inspeção tipo WAF nas requisições de entrada e encaminha o tráfego para o backend correto. Um forward proxy representa clientes internos para o exterior, não o contrário. Um jump server intermedia sessões administrativas, não tráfego de clientes. Um IDS passivo apenas observa e não termina TLS nem encaminha tráfego.

Questão 4: Alternativa A — Um load balancer que realiza health checks, distribui o tráfego via round-robin ou least-connections e faz offloading da descriptografia TLS para otimizar o desempenho dos backends

Um load balancer (hardware ou software) é a solução canônica para distribuir tráfego entre múltiplos servidores, realizar health checks ativos para remover nós com falha e fazer offloading de TLS para reduzir a carga de CPU nos backends. Um reverse proxy sozinho normalmente atende um único servidor. Um jump server é para acesso administrativo. Um IPS bloqueia ataques, mas não distribui nem faz balanceamento de tráfego.

Questão 5: Alternativa A — Um sensor IDS passivo conectado a uma porta SPAN/mirror que analisa cópias do tráfego e gera alertas em correspondências de assinatura

Um sensor IDS (Intrusion Detection System) é um appliance de monitoramento passivo que recebe cópias do tráfego (tipicamente via porta SPAN ou TAP) e alerta sobre padrões suspeitos sem alterar o tráfego. A pergunta explicitamente proíbe modificação, o que descarta um IPS inline. Um reverse proxy e um load balancer não são dispositivos de detecção.

Questão 6: Alternativa A — Um sensor IPS inline colocado no caminho da rede que realiza inspeção profunda de pacotes e bloqueia ativamente o tráfego malicioso

Um IPS (Intrusion Prevention System) é a contraparte inline de um IDS. Ele bloqueia ativamente o tráfego malicioso com base em assinaturas, anomalias ou regras comportamentais. O requisito de posicionamento inline e bloqueio em tempo real mapeia claramente para um IPS. Um IDS passivo só alerta, um reverse proxy neste contexto não imporia bloqueio baseado em assinatura e um jump server não tem relação.

Questão 7: Alternativa A — Um coletor de logs que recebe eventos de diversas fontes, normaliza em um esquema comum, enriquece os dados e os encaminha para o SIEM

Um coletor (ou coletor/forwarder de logs) é projetado especificamente para ingerir logs de muitas fontes heterogêneas, normalizar os dados em um formato consistente e encaminhar os eventos normalizados para um SIEM para correlação e análise. As outras opções ou produzem logs incidentemente ou não são projetadas para coleta centralizada de logs de múltiplas fontes.

Questão 8: Alternativa A — Um SIEM que ingere eventos normalizados de múltiplos coletores, correlaciona entre fontes e fornece dashboards e alertas

Um SIEM (Security Information and Event Management) é a plataforma construída para agregação centralizada de logs, normalização, correlação entre fontes diversas de logs e alerta sobre padrões complexos de ataques multi-estágio. As outras opções descrevem appliances que produzem logs ou bloqueiam tráfego, mas não são motores de correlação entre fontes heterogêneas.

Questão 9: Alternativa A — Implantar um jump server reforçado na VLAN de gerenciamento, exigir que todos os admins se autentiquem nele primeiro e encaminhar seus logs de sessão para o SIEM

Um jump server é a solução clássica para consolidar acesso administrativo, eliminar serviços administrativos de entrada direta da Internet e produzir logs de auditoria centralizados da atividade administrativa. As outras opções ou enfraquecem a segurança (abrir SSH, sem autenticação) ou falham em intermediar o acesso administrativo (IDS, reverse proxy).

Questão 10: Alternativa A — Forward proxy para tráfego de saída dos clientes, reverse proxy na DMZ para tráfego web de entrada, sensor IDS/IPS no perímetro para detecção/prevenção e jump server para acesso administrativo

Cada appliance tem um papel definido em um perímetro bem projetado: forward proxy = tráfego de saída dos clientes para a Internet, reverse proxy = tráfego web de entrada na DMZ, sensor IDS/IPS = inspeção/detecção/prevenção no perímetro, jump server = acesso administrativo. As outras opções trocam os papéis incorretamente, demonstrando que a resposta exige entender o propósito de cada appliance.